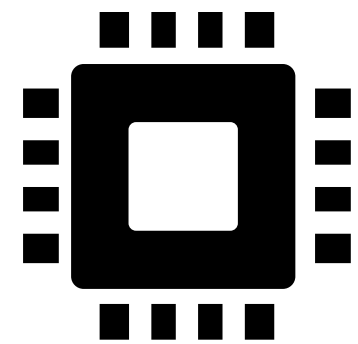
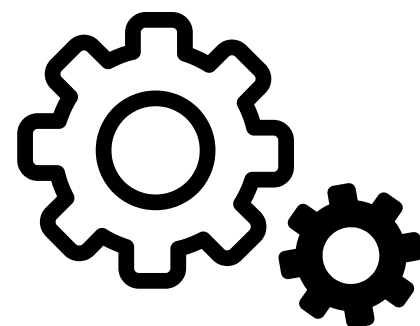




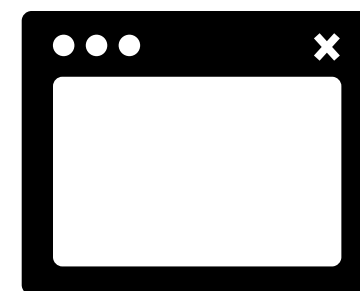
Authenticator (Hardware)

TPM, Secure Enclave, Yubikey



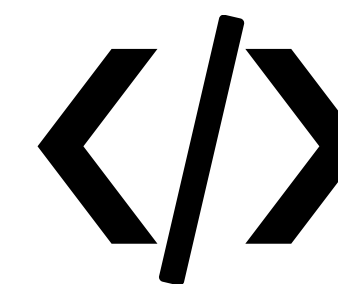
Operating System

Windows Hello, macOS/iOS system APIs, Android Credential Manager



Browser (WebAuthn API)

Chrome, Firefox, Safari



Web Application (Client-side JS)

Bitwarden, Dashlane, wwWallet



4 User verifies presence (fingerprint, PIN, tap, etc.)

3 Sends CTAP2 hmac-secret command to Authenticator

2 Browser hashes PRF inputs (salt and domain prefix)

1 Relying party generates salt and requests PRF evaluation by a WebAuthn call

5 Calculates PRF via HMAC with hashed salt + secret key

6 Returns 32-byte string. Secret key never leaves.

7 Forwards PRF result to browser

8 Returns response to application

9 Receives 32-byte string, uses it as symmetric key

Must support CTAP2 hmac-secret extension

Authenticator (Hardware)

Must relay CTAP2 hmac-secret extension to authenticator

Operating System

Must recognize PRF extension in WebAuthn API

Browser (WebAuthn API)

Must request PRF and handle the derived key

Web Application (Client-side JS)